

FinSecure Banking — TPRM Vendor Assessment Report

Payment Processor Vendor Due Diligence (SwiftPay Solutions) — OCC Bulletin 2013-29 · PCI DSS v4.0 · SOC 2 Type II

FINSECURE BANKING

Financial Services | 1,200 Employees

Third-Party Risk Management Assessment

Payment Processor Vendor Due Diligence

PCI DSS | SOC 2 Type II | OCC Regulatory Compliance

Document:	TPRM Vendor Assessment Report
Institution:	FinSecure Banking (1,200 employees, FDIC-insured)
Vendor:	SwiftPay Solutions — Payment Processing Services
Regulatory:	OCC Bulletin 2013-29 (Third-Party Relationships) PCI DSS v4.0 SOC 2 Type II
Prepared By:	TPRM Lead — GRC Department
Date:	March 2026
Classification:	CONFIDENTIAL — RESTRICTED

1. EXECUTIVE SUMMARY

FinSecure Banking, a mid-size FDIC-insured financial institution with 1,200 employees, is integrating a third-party payment processor called SwiftPay Solutions. SwiftPay will have direct access to FinSecure's cardholder data environment (CDE), processing credit and debit card transactions for the bank's retail and commercial customers. This integration is subject to OCC Bulletin 2013-29 governing third-party relationships, PCI DSS v4.0 requirements for protecting cardholder data, and SOC 2 Type II attestation requirements for service organizations.

As the TPRM Lead, this assessment covers: a complete vendor profile evaluating SwiftPay's security posture, 4 vendor-specific risks with likelihood and impact scoring, verification of 6 security controls mapped to PCI DSS and SOC 2 frameworks, and 3 remediation issues identified during the assessment that require resolution before full production integration.

2. VENDOR PROFILE — SWIFTPAY SOLUTIONS

Before assessing risks, we need to understand WHO we are doing business with. The vendor profile captures everything we need to evaluate SwiftPay's suitability as a payment processor for FinSecure Banking.

2.1 Vendor Profile Card

FIELD	DETAILS
Name	SwiftPay Solutions Inc.
Service	Payment card processing (credit/debit card authorization, settlement, and clearing). SwiftPay handles the full transaction lifecycle: card authorization at point-of-sale, routing to card networks (Visa/Mastercard), settlement to merchant accounts, and chargeback management. They process approximately 2.3 million transactions per month for mid-market financial institutions.
Criticality	Critical
Owner	VP of Payment Operations
Status	Under Review
Notes	SwiftPay is a payment processing company that has been operating for 8 years and is headquartered in Dallas, Texas, with about 450 employees, and it currently provides services to 34 financial institutions across the United States. The company has a SOC 2 Type II report covering January 2025 to December 2025 with an unqualified audit opinion, meaning the auditors found the controls to be properly designed and operating effectively during that period. SwiftPay is also certified as a Level 1 service provider under PCI DSS, with the most recent Qualified Security Assessor review completed in September 2025. The company maintains \$10 million in cyber liability insurance to cover potential cybersecurity incidents, and its main data center infrastructure runs in Amazon Web Services in the US East (Virginia) region with a disaster recovery environment in the US West (Oregon) region. SwiftPay generates approximately \$85 million in annual revenue and has maintained positive cash flow for the past five years.

3. VENDOR RISK ASSESSMENT

With the vendor profile established, we now assess the specific risks that SwiftPay introduces to FinSecure Banking. Each risk is scored using the same 5x5 likelihood-impact matrix.

Vendor Risk 1: Cardholder Data Breach at SwiftPay

FIELD	DETAILS
Title	Cardholder Data Breach at Third-Party Payment Processor
Category	Data Protection
Status	Open
Likelihood	3 — Possible
Impact	5 — Severe
Risk Score	15 (3 × 5) — CRITICAL
Owner	VP of Payment Operations

FIELD	DETAILS
Description	SwiftPay processes about 2.3 million card transactions every month for FinSecure, which means the company handles sensitive cardholder information such as Primary Account Numbers (card numbers), expiration dates, and CVV codes during transaction authorization. If a data breach happens at SwiftPay, the card information of FinSecure's customers could be exposed, which would require the bank to activate incident response procedures under PCI DSS, reissue affected cards at an estimated cost of \$5 to \$25 per card, notify regulators like the Office of the Comptroller of the Currency, and potentially face fines from card brands such as Visa and Mastercard, while also informing customers and dealing with reputational damage. According to card network rules, the acquiring bank (FinSecure) is financially responsible for compromised cardholder data even if the security breach occurs at the third-party payment processor.

Vendor Risk 2: SwiftPay Service Outage Disrupting Payment Processing

FIELD	DETAILS
Title	Payment Processing Service Outage Due to Vendor System Failure
Category	Availability
Status	Open
Likelihood	3 — Possible
Impact	4 — Major
Risk Score	12 (3 × 4) — HIGH
Owner	VP of Payment Operations
Description	If SwiftPay experiences a system outage, FinSecure's customers will not be able to process credit or debit card transactions at merchants or ATMs. SwiftPay promises 99.95% system uptime in its Service Level Agreement (SLA), which means about 4.38 hours of downtime per year is allowed, but their disaster recovery site has a Recovery Time Objective (RTO) of 4 hours and a Recovery Point Objective (RPO) of 15 minutes, meaning that during a major incident the payment system could be unavailable for up to four hours and up to fifteen minutes of transaction data could potentially be lost. During such an outage, FinSecure could receive many customer complaints, lose transaction revenue, damage relationships with merchants, and face negative media coverage, and banking regulators such as the Office of the Comptroller of the Currency consider payment processing availability to be critical for maintaining safe and reliable banking operations.

Vendor Risk 3: Regulatory Non-Compliance by SwiftPay

FIELD	DETAILS
Title	Vendor Regulatory Non-Compliance Impacting FinSecure's Compliance Status
Category	Compliance
Status	Open
Likelihood	2 — Unlikely

FIELD	DETAILS
Impact	5 — Severe
Risk Score	10 (2 × 5) — HIGH
Owner	Chief Compliance Officer
Description	If SwiftPay does not maintain its certification under PCI DSS or receives a negative audit opinion in its SOC 2 report, FinSecure could be considered non-compliant with the third-party risk management expectations of the Office of the Comptroller of the Currency, because banks are responsible for ensuring their vendors meet security and compliance requirements. This situation could lead to regulatory consequences such as enforcement actions or financial penalties from the OCC, possible restrictions on FinSecure's ability to process card transactions, mandatory issues called Matters Requiring Attention (MRAs) in the OCC examination report, more frequent and stricter regulatory audits, and potential damage to the bank's CAMELS rating, which regulators use to evaluate a bank's financial and operational health. In addition, if SwiftPay does not comply with the updated PCI DSS version 4.0 requirements by March 2025, then all card transactions processed through SwiftPay could be considered non-compliant with PCI standards.

Vendor Risk 4: Fourth-Party Risk from SwiftPay's Subcontractors

FIELD	DETAILS
Title	Unmanaged Fourth-Party Risk Through SwiftPay's Sub-Service Organizations
Category	Vendor Risk
Status	Open
Likelihood	3 — Possible
Impact	4 — Major
Risk Score	12 (3 × 4) — HIGH
Owner	TPRM Lead — GRC Department
Description	SwiftPay uses Stripe as a backup/overflow payment processor and AWS as their infrastructure provider. These are 'fourth parties' from FinSecure's perspective — vendors of our vendor. FinSecure has no direct contractual relationship with Stripe or AWS, and limited visibility into their security posture. SwiftPay's SOC 2 report uses the 'carve-out method' for Stripe, meaning Stripe's controls are EXCLUDED from the auditor's testing. If Stripe experiences a breach or outage that affects SwiftPay, FinSecure's payment processing could be impacted with no advance warning and no direct recourse. Additionally, FinSecure does not currently receive notification when SwiftPay onboards new sub-service organizations.

4. VENDOR RISK SUMMARY

#	Risk Title	L	I	Score	Rating	Category
VR-01	Cardholder Data Breach at SwiftPay	3	5	15	CRITICAL	Data Protection

#	Risk Title	L	I	Score	Rating	Category
VR-02	Payment Processing Service Outage	3	4	12	HIGH	Availability
VR-03	Vendor Regulatory Non-Compliance	2	5	10	HIGH	Compliance
VR-04	Fourth-Party Subcontractor Risk	3	4	12	HIGH	Vendor Risk

5. CONTROL CATALOG — VERIFICATION OF 6 CONTROLS

As TPRM Lead, we must VERIFY that SwiftPay has implemented adequate security controls. Verification means reviewing evidence, not just taking SwiftPay's word for it. Below are 6 controls verified through their SOC 2 Type II report, PCI DSS Attestation of Compliance, and direct evidence requests.

Control 1: Cardholder Data Encryption

FIELD	DETAILS
Name	Encryption of Cardholder Data at Rest and in Transit
Framework	PCI DSS
Reference	PCI DSS v4.0 Requirement 3.5 (protect stored account data) and Requirement 4.2 (protect cardholder data with strong cryptography during transmission)
Effectiveness	Partially Effective
Frequency	Continuous
Owner	SwiftPay CISO — verified by FinSecure TPRM Lead
Description	SwiftPay protects all cardholder data stored in its systems by using AES-256 encryption in its databases and storage services running on Amazon Web Services, specifically in AWS RDS databases and S3 storage. The encryption keys are managed through AWS KMS and are rotated once every year for security. For data that moves across the network, SwiftPay requires a minimum of TLS 1.2 encryption on all API connections and payment processing channels to ensure secure transmission of card data. Their Attestation of Compliance confirms that they meet Requirements 3 and 4 of PCI DSS, which cover protection of stored data and encryption of data in transit. However, the company has not yet upgraded to TLS 1.3, which is considered the current industry best practice and is expected under the updated cryptographic guidance in PCI DSS version 4.0. The vendor's SOC 2 audit report also confirmed that the encryption controls worked effectively during the audit period and no issues were identified with the encryption of stored data.

Control 2: Access Control to Cardholder Data Environment

FIELD	DETAILS
Name	Logical Access Control to Cardholder Data Environment (CDE)

FIELD	DETAILS
Framework	PCI DSS
Reference	PCI DSS v4.0 Requirement 7 (restrict access to system components and cardholder data by business need to know) and Requirement 8 (identify users and authenticate access)
Effectiveness	Effective
Frequency	Continuous (with quarterly access reviews)
Owner	SwiftPay CISO — verified by FinSecure TPRM Lead
Description	SwiftPay controls access to its cardholder data environment by using role-based access control (RBAC), which means employees only get access to the systems and data they need for their specific job roles. Out of the company's 450 employees, only 23 employees are allowed to access the cardholder data environment, and each of them has limited permissions based on their responsibilities. To improve security, SwiftPay requires multi-factor authentication (MFA) for anyone accessing this environment, using hardware security tokens for administrators and time-based one-time passwords for regular users. The company also performs quarterly access reviews through its internal audit team to make sure only the right people still have access. All access to the cardholder data environment is recorded and monitored using a SIEM (Security Information and Event Management) system, and the logs are kept for 90 days for monitoring and investigation purposes. During the audit for SOC 2, the auditors reviewed how access is granted, changed, and removed, and they did not find any problems. When an employee leaves the company, their system access is removed within four hours.

Control 3: Vulnerability Management and Patching

FIELD	DETAILS
Name	Vulnerability Management and Security Patching Program
Framework	PCI DSS
Reference	PCI DSS v4.0 Requirement 6.3 (identify and address security vulnerabilities) and Requirement 11.3 (external and internal vulnerability scanning)
Effectiveness	Effective
Frequency	Continuous (scans monthly, critical patches within 72 hours)
Owner	SwiftPay VP of Engineering — verified by FinSecure TPRM Lead
Description	SwiftPay performs monthly internal vulnerability scans using Qualys and quarterly external scans through an Approved Scanning Vendor using Trustwave to identify security weaknesses in their systems. If a critical vulnerability with a CVSS score of 9.0 or higher is found, it must be fixed within 72 hours, while high vulnerabilities with scores between 7.0 and 8.9 must be fixed within 14 days. SwiftPay also performs an annual penetration test conducted by an independent security firm, NCC Group. The most recent penetration test in October 2025 identified two medium-level security issues and no critical or high issues, and both medium issues were fixed within 30 days. The vendor's SOC 2 audit report also confirmed that their vulnerability management processes were working properly during the audit period and no problems were identified.

Control 4: Incident Response and Notification

FIELD	DETAILS
Name	Security Incident Response Plan with Client Notification
Framework	SOC 2
Reference	SOC 2 Trust Services Criteria CC7.3 (response to identified security incidents) and CC7.4 (incident recovery) PCI DSS Requirement 12.10
Effectiveness	Partially Effective
Frequency	Continuous (plan tested annually via tabletop exercise)
Owner	SwiftPay CISO — verified by FinSecure TPRM Lead
Description	SwiftPay has a documented incident response plan that explains how the company handles security incidents, including defining different severity levels, escalation procedures, and the roles and responsibilities of the response team. The company tests this plan once a year through tabletop exercises to make sure employees understand how to respond to incidents. However, SwiftPay's policy states that clients will be notified within 72 hours after confirming an incident, which does not meet FinSecure's stricter requirement of notifying within 24 hours if an incident affects cardholder data. The audit report for SOC 2 confirmed that the incident response plan exists and is tested, but the auditor also noted an "other matter" observation because during the audit period SwiftPay sent a notification about a non-critical incident 71 hours after confirmation, which was close to the 72-hour limit.

Control 5: Business Continuity and Disaster Recovery

FIELD	DETAILS
Name	Business Continuity Plan and Disaster Recovery for Payment Processing
Framework	SOC 2
Reference	SOC 2 Trust Services Criteria A1.2 (recovery objectives) and A1.3 (recovery testing) PCI DSS Requirement 12.10.2
Effectiveness	Effective
Frequency	Annual (DR test conducted annually, BCP reviewed quarterly)
Owner	SwiftPay VP of Operations — verified by FinSecure TPRM Lead

FIELD	DETAILS
Description	SwiftPay runs its main data center on Amazon Web Services in the us-east-1 region (Virginia) and keeps a disaster recovery site in the us-west-2 region (Oregon) so that services can continue if the primary system fails. The company states that its Recovery Time Objective (RTO) is 4 hours, which means the system should be restored within four hours after a failure, and its Recovery Point Objective (RPO) is 15 minutes, meaning no more than 15 minutes of data should be lost during an incident. SwiftPay uses RDS Multi-AZ to automatically switch the database to another availability zone if a failure occurs, and it uses S3 cross-region replication to copy static data to the backup region. The company performs annual disaster recovery failover tests, and during the most recent test in August 2025 the system recovered in 3.2 hours with 8 minutes of data loss, which was better than the stated targets. Their Business Continuity Plan (BCP) is reviewed every quarter and approved by the company's executive leadership. The audit report for SOC 2 also confirmed that disaster recovery testing was completed and met the stated recovery objectives.

Control 6: Logging, Monitoring, and Audit Trail

FIELD	DETAILS
Name	Security Logging, Monitoring, and Audit Trail Retention
Framework	PCI DSS
Reference	PCI DSS v4.0 Requirement 10 (log and monitor all access to system components and cardholder data) SOC 2 CC7.2 (monitoring of system components)
Effectiveness	Effective
Frequency	Continuous
Owner	SwiftPay Security Operations Center — verified by FinSecure TPRM Lead
Description	SwiftPay runs a 24/7 Security Operations Center (SOC) that constantly monitors all systems that handle cardholder data. Every access to these systems is recorded, including who accessed it (user ID), when (timestamp), what action was taken, and whether it succeeded or failed. All these logs are collected in a Splunk SIEM system, which automatically generates alerts for suspicious activities, such as multiple failed logins, access outside working hours, large data queries, or attempts to gain higher privileges. The logs are kept online for 12 months and stored in long-term cold storage for 7 years, meeting PCI DSS rules that require at least 12 months of logging. The SOC 2 audit confirmed that all monitoring and alerts were handled properly and investigated within the required timeframes.

6. ISSUE TRACKER — 3 REMEDIATION ISSUES

During the vendor assessment, three issues were identified that require remediation before or shortly after full production integration. These issues do not block the initial integration but must be resolved within defined timelines to maintain FinSecure's risk appetite.

Remediation Issue 1: Incident Notification SLA Gap

FIELD	DETAILS
Title	SwiftPay Incident Notification SLA Exceeds FinSecure's 24-Hour Requirement

FIELD	DETAILS
Category	Process Gap
Severity	High
Status	Open
Owner	TPRM Lead + SwiftPay Account Manager
Due Date	June 30, 2026 (90 days from contract execution)
Description	SwiftPay currently takes up to 72 hours to notify clients after confirming a security incident. However, FinSecure's policy requires vendors to notify within 24 hours for any incident affecting cardholder data or service availability. The SOC 2 audit also noted that one notification was sent at 71 hours, showing that SwiftPay is already at the limit of their own SLA. This delay creates regulatory risk for FinSecure, because banking regulators like the OCC expect banks to be informed quickly about critical vendor incidents, and FDIC rules require banks to report security incidents within 36 hours — which is impossible if the vendor waits 72 hours. Remediation required: FinSecure should update the contract with SwiftPay to reduce their notification time from 72 hours to 24 hours for incidents involving cardholder data, personal information, or service outages longer than 30 minutes. SwiftPay should also provide quarterly reports listing all incidents and when they were reported.

Remediation Issue 2: TLS 1.2 Instead of TLS 1.3 for Data in Transit

FIELD	DETAILS
Title	SwiftPay Uses TLS 1.2 for Data in Transit Instead of TLS 1.3
Category	Technical Debt
Severity	Medium
Status	Open
Owner	SwiftPay VP of Engineering + FinSecure Information Security Officer
Due Date	December 31, 2026 (within 12 months)
Description	SwiftPay currently uses TLS 1.2 for all data in transit, including the API connections that carry cardholder data between FinSecure and SwiftPay's systems. TLS 1.2 meets current PCI DSS standards, but TLS 1.3 is stronger because it removes unsafe encryption methods, speeds up connections (so payments are faster), and provides forward secrecy by default. Security guidelines like NIST SP 800-52 Rev.2 recommend TLS 1.3, and PCI DSS v4.0 increasingly prefers it. SwiftPay plans to implement TLS 1.3 in 2026 but hasn't set an exact date. Remediation required: SwiftPay must provide a documented plan for migrating to TLS 1.3, with milestones, and commit to completing it by December 31, 2026. FinSecure won't block integration if TLS 1.3 isn't ready yet, but it will be a contractual milestone.

Remediation Issue 3: Limited Fourth-Party Visibility

FIELD	DETAILS
Title	Insufficient Visibility into SwiftPay's Sub-Service Organizations (Fourth-Party Risk)
Category	Compliance Issue

FIELD	DETAILS
Severity	High
Status	Open
Owner	TPRM Lead + SwiftPay Chief Compliance Officer
Due Date	September 30, 2026 (180 days from contract execution)
Description	SwiftPay's SOC 2 Type II report uses the "carve-out method" for Stripe, their backup payment processor. This means Stripe's security controls were not included in the SOC 2 audit — the auditor intentionally excluded Stripe's systems. Also, FinSecure currently has no way to know when SwiftPay adds a new sub-service organization. This is a problem because banking regulations (OCC Bulletin 2013-29) require banks to understand the risks of important subcontractors. Remediation required: SwiftPay must provide Stripe's SOC 2 Type II report or an equivalent proof of compliance for FinSecure to review. SwiftPay must contractually agree to notify FinSecure within 30 days whenever a new sub-service organization that handles cardholder data or payment processing is onboarded. SwiftPay must maintain a list of all sub-service organizations as part of their annual vendor due diligence package.

7. ASSESSMENT SUMMARY & RECOMMENDATION

7.1 Overall Vendor Assessment Summary

Assessment Area	Count / Result	Overall Status
Vendor Criticality	Critical	Enhanced due diligence applied
Vendor Risks Identified	4 (1 Critical, 3 High)	All within risk appetite with controls
Controls Verified	6 (4 Effective, 2 Partially Effective)	Acceptable with remediation
Remediation Issues	3 (2 High, 1 Medium)	Must be resolved per timeline
SOC 2 Type II	Unqualified opinion (Deloitte)	Satisfactory
PCI DSS Certification	Level 1 SP, 0 findings (QSA: Sep 2025)	Satisfactory

7.2 Recommendation

RECOMMENDATION: CONDITIONAL APPROVAL — Proceed with SwiftPay integration subject to the three remediation items being resolved within their specified timelines. The vendor demonstrates a mature security posture with clean PCI DSS certification and unqualified SOC 2 Type II opinion. The identified gaps (notification SLA, TLS version, and fourth-party visibility) are manageable and do not represent blocking risks for initial integration. However, the contract **MUST** include: (a) the remediation milestones as contractual obligations, (b) a right-to-audit clause, (c) performance SLAs with financial penalties, and (d) termination provisions if Critical remediation items are not resolved.